

Scénario 1 — Attaque brute force SSH

Objectif : tester la capacité de Wazuh à détecter une attaque automatisée par force brute contre le service SSH de la machine cible.

Capture 1 — Lancement de l'installation Wazuh (all-in-one)

```
root@wazuhserver:~# curl -sO https://packages.wazuh.com/4.9/wazuh-install.sh
root@wazuhserver:~# bash wazuh-install.sh -a
10/09/2026 15:24:44 INFO: Starting Wazuh installation assistant. Wazuh version: 4.9.2
10/09/2026 15:24:44 INFO: Verbose logging redirected to /var/log/wazuh-install.log
10/09/2026 15:24:44 INFO: The recommended systems are: Red Hat Enterprise Linux 7, 8, 9; CentOS 7, 8; Amazon Linux 2; Ubuntu 16.04, 18.04, 20.04, 22.04.
10/09/2026 15:24:44 WARNING: The current system does not match with the list of recommended systems. The installation may not work properly.
10/09/2026 15:24:44 INFO: Verifying that your system meets the recommended minimum hardware requirements.
10/09/2026 15:24:54 ERROR: Your system does not meet the recommended minimum hardware requirements of 4Gb of RAM and 2 CPU cores. If you want to proceed with the installation use the -i option to ignore these requirements.
root@wazuhserver:~# bash wazuh-install.sh -a -i
10/09/2026 15:25:49 INFO: Starting Wazuh installation assistant. Wazuh version: 4.9.2
10/09/2026 15:25:49 INFO: Verbose logging redirected to /var/log/wazuh-install.log
10/09/2026 15:25:49 INFO: The recommended systems are: Red Hat Enterprise Linux 7, 8, 9; CentOS 7, 8; Amazon Linux 2; Ubuntu 16.04, 18.04, 20.04, 22.04.
10/09/2026 15:25:49 WARNING: The current system does not match with the list of recommended systems. The installation may not work properly.
10/09/2026 15:25:58 WARNING: Hardware checks ignored.
10/09/2026 15:25:58 INFO: Wazuh web interface port will be 443.
10/09/2026 15:25:59 INFO: --- Dependencies ---
10/09/2026 15:25:59 INFO: Installing lsuf.
10/09/2026 15:26:13 INFO: --- Dependencies ---
10/09/2026 15:26:13 INFO: Installing apt-transport-https.
10/09/2026 15:26:17 INFO: Installing debhelper.
10/09/2026 15:26:51 INFO: Wazuh repository added.
10/09/2026 15:26:52 INFO: --- Configuration files ---
10/09/2026 15:26:52 INFO: Generating configuration files.
10/09/2026 15:26:53 INFO: Generating the root certificate.
10/09/2026 15:26:53 INFO: Generating Admin certificates.
10/09/2026 15:26:54 INFO: Generating Wazuh Indexer certificates.
10/09/2026 15:26:54 INFO: Generating Filebeat certificates.
10/09/2026 15:26:54 INFO: Generating Wazuh dashboard certificates.
10/09/2026 15:26:56 INFO: Created wazuh-install-files.tar. It contains the Wazuh cluster key, certificates, and passwords necessary for installation.
10/09/2026 15:26:57 INFO: --- Wazuh Indexer ---
10/09/2026 15:26:57 INFO: Starting Wazuh Indexer installation.
10/09/2026 15:28:54 INFO: Wazuh Indexer installation finished.
10/09/2026 15:28:54 INFO: Wazuh Indexer post-install configuration finished.
10/09/2026 15:28:54 INFO: Starting service wazuh-indexer.
10/09/2026 15:29:43 INFO: wazuh-indexer service started.
10/09/2026 15:29:43 INFO: Initializing Wazuh Indexer cluster security settings.
10/09/2026 15:29:59 INFO: Wazuh Indexer cluster security configuration initialized.
10/09/2026 15:30:00 INFO: Wazuh Indexer cluster initialized.
10/09/2026 15:30:00 INFO: Wazuh Indexer
```

Sur la VM Ubuntu Server dédiée à Wazuh, le script d'installation officiel (wazuh-install.sh) est exécuté avec l'option -a pour une installation « all-in-one » (manager, indexer et dashboard sur la même machine). Le journal affiche d'abord un avertissement sur les ressources matérielles minimales recommandées (4 Go de RAM, 2 cœurs CPU), contourné avec l'option -i, puis les premières étapes : génération des certificats internes et démarrage de l'installation du Wazuh Indexer.

Capture 2 — Fin de l'installation et identifiants générés

```

02/09/2026 15:30:00 INFO: Wazuh indexer cluster initialized.
02/09/2026 15:30:00 INFO: --- Wazuh server ---
02/09/2026 15:30:00 INFO: Starting the Wazuh manager installation.
02/09/2026 15:37:55 INFO: Wazuh manager installation finished.
02/09/2026 15:37:55 INFO: Wazuh manager vulnerability detection configuration finished.
02/09/2026 15:37:55 INFO: Starting service wazuh-manager.
02/09/2026 15:38:24 INFO: wazuh-manager service started.
02/09/2026 15:38:24 INFO: Starting Filebeat installation.
02/09/2026 15:38:48 INFO: Filebeat installation finished.
02/09/2026 15:38:51 INFO: Filebeat post-install configuration finished.
02/09/2026 15:38:51 INFO: Starting service filebeat.
02/09/2026 15:38:57 INFO: filebeat service started.
02/09/2026 15:38:57 INFO: --- Wazuh dashboard ---
02/09/2026 15:38:57 INFO: Starting Wazuh dashboard installation.
02/09/2026 15:43:25 INFO: Wazuh dashboard installation finished.
02/09/2026 15:43:25 INFO: Wazuh dashboard post-install configuration finished.
02/09/2026 15:43:25 INFO: Starting service wazuh-dashboard.
02/09/2026 15:43:28 INFO: wazuh-dashboard service started.
02/09/2026 15:43:33 INFO: Updating the internal users.
02/09/2026 15:43:54 INFO: A backup of the internal users has been saved in the /etc/wazuh-indexer/internalusers-backup folder.
02/09/2026 15:44:54 INFO: The filebeat.yml file has been updated to use the Filebeat Keystore username and password.
02/09/2026 15:46:41 INFO: Initializing Wazuh dashboard web application.
02/09/2026 15:46:42 INFO: Wazuh dashboard web application not yet initialized. Waiting...
02/09/2026 15:46:57 INFO: Wazuh dashboard web application not yet initialized. Waiting...
02/09/2026 15:47:10 INFO: Wazuh dashboard web application not yet initialized. Waiting...
02/09/2026 15:47:29 INFO: Wazuh dashboard web application initialized.
02/09/2026 15:47:29 INFO: --- Summary ---
02/09/2026 15:47:29 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443
User: admin
Password: L5xKE4GtJHHC+pdX5JtuFIS40kvW9WnJ
02/09/2026 15:47:29 INFO: --- Dependencies ---
02/09/2026 15:47:29 INFO: Removing lsuf.
02/09/2026 15:47:39 INFO: Installation finished.
root@wazuhserver:~#

```

Suite du journal d'installation : configuration du Wazuh Manager, de Filebeat (transport des données vers l'indexer) puis du Wazuh Dashboard. Une fois l'application web initialisée, le script affiche l'URL d'accès (<https://<wazuh-dashboard-ip>:443>) ainsi que les identifiants administrateur générés automatiquement (utilisateur admin et mot de passe aléatoire), marquant la fin réussie de l'installation.

Capture 3 — Téléchargement de l'agent Wazuh sur la VM cible

```

aby@wazuhagent:~$ sudo /var/ossec/bin/manage_agents
[sudo: authenticate] Password:
sudo: /var/ossec/bin/manage_agents: command not found
aby@wazuhagent:~$ wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.9.2-1_and64.deb
--2026-09-10 22:51:01-- https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.9.2-1_and64.deb
Resolving packages.wazuh.com (packages.wazuh.com)... 3.162.36.84, 3.162.36.109, 3.162.36.122, ...
Connecting to packages.wazuh.com (packages.wazuh.com)|3.162.36.84|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 16774582 (16M) [application/vnd.debian.binary-package]
Saving to: 'wazuh-agent_4.9.2-1_and64.deb'

wazuh-agent_4.9.2-1_and64.deb
100%[=====] 16,77M 13,7KB/s in 14m.42s

2026-09-10 23:05:52 (11,9 KB/s) - 'wazuh-agent_4.9.2-1_and64.deb' saved [16774582/16774582]
aby@wazuhagent:~$

```

Sur la VM cible (nommée « wazuhagent »), le paquet .deb de l'agent Wazuh est téléchargé manuellement via wget depuis le dépôt officiel packages.wazuh.com, en vue d'une installation locale et d'un rattachement ultérieur au manager.

Capture 4 — Installation et enregistrement de l'agent

```

aby@wazuhagent:~$ sudo WAZUH_MANAGER='192.168.121.173' dpkg -i ./wazuh-agent_4.9.2-1_amd64.deb
Sélection du paquet wazuh-agent précédemment désélectionné.
(Lecture de la base de données... 136592 fichiers et répertoires déjà installés.)
Préparation du paquetage de /var/cache/apt/archives/wazuh-agent_4.9.2-1_amd64.deb
Dépaquetage de wazuh-agent (4.9.2-1) ...
Paramétrage de wazuh-agent (4.9.2-1) ...
aby@wazuhagent:~$ sudo /var/ossec/bin/manage_agents

*****
* Wazuh v4.9.2 Agent manager.
* The following options are available: *
*****
(I) Import key from the server (I).
(Q) Quit.
Choose your action: I or Q: i

* Provide the Key generated by the server.
* The best approach is to cut and paste it.
*** Use: do not include spaces or new lines.

Paste it here (or '\q' to quit): MDAXIGfNzK50x3VldK5edSxvOTIuMTY4LjEgYMS4xNzUgN2UyODU5YmQ4MmZyY3Y2U1ZjMjYjYTNlMzg2N2UwNDk4MzRkMGI1ZmU3NDZlNmNhM2ZjYVY1NjM4Mjk0ZDY1MGRhMQ==

Agent information:
ID: 001
Name: agent_ubuntu
IP Address: 192.168.121.175

Confirm adding it? (y/n): y
Added.

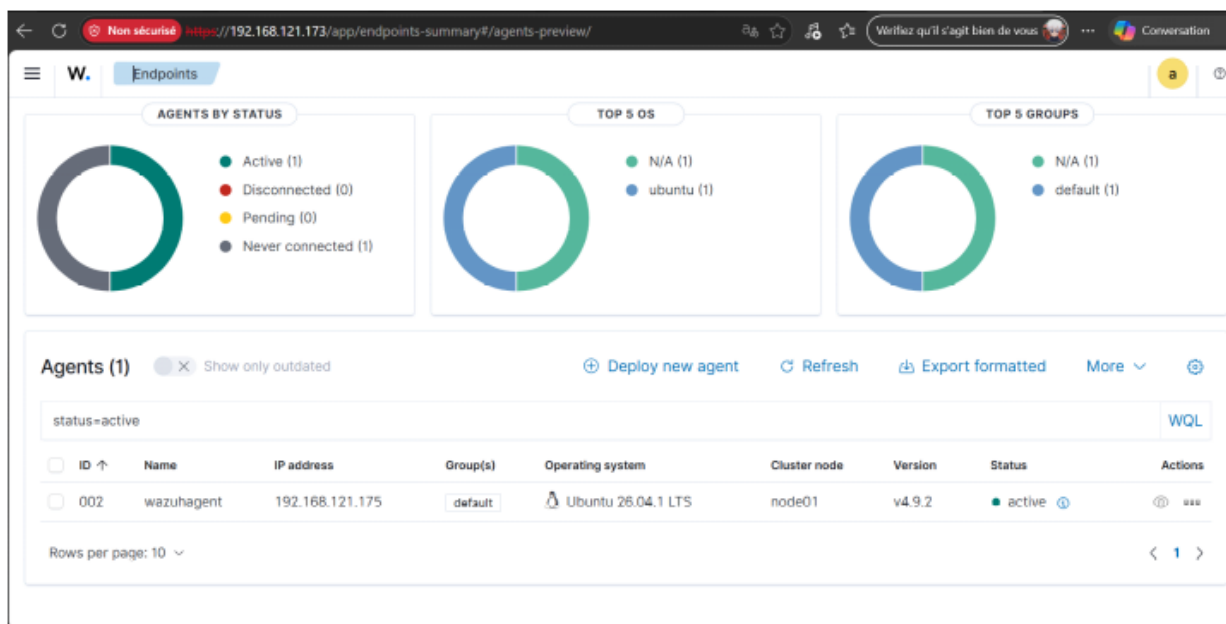
*****
* Wazuh v4.9.2 Agent manager.
* The following options are available: *
*****
(I) Import key from the server (I).
(Q) Quit.
Choose your action: I or Q: q

manage_agents: Exiting.
aby@wazuhagent:~$ sudo systemctl daemon-reload
aby@wazuhagent:~$ sudo systemctl enable wazuh-agent --now
Created symlink /etc/systemd/system/multi-user.target.wants/wazuh-agent.service' → /usr/lib/systemd/system/wazuh-agent.service'.
aby@wazuhagent:~$

```

Le paquet est installé avec dpkg, puis l'outil manage_agents est utilisé pour importer la clé d'enregistrement générée côté manager (option « I »). Une fois la clé collée, les informations de l'agent (ID, nom, adresse IP) sont confirmées et ajoutées. Les commandes systemctl daemon-reload et systemctl enable --now wazuh-agent activent ensuite le service au démarrage du système.

Capture 5 — Agent visible et actif dans le dashboard



Le dashboard Wazuh (module Endpoints) confirme que l'agent « wazuhagent » (192.168.121.175, Ubuntu 26.04 LTS) apparaît bien avec le statut « active » dans le groupe par défaut. Cette étape valide que la liaison agent-manager fonctionne correctement avant de lancer les scénarios d'attaque.

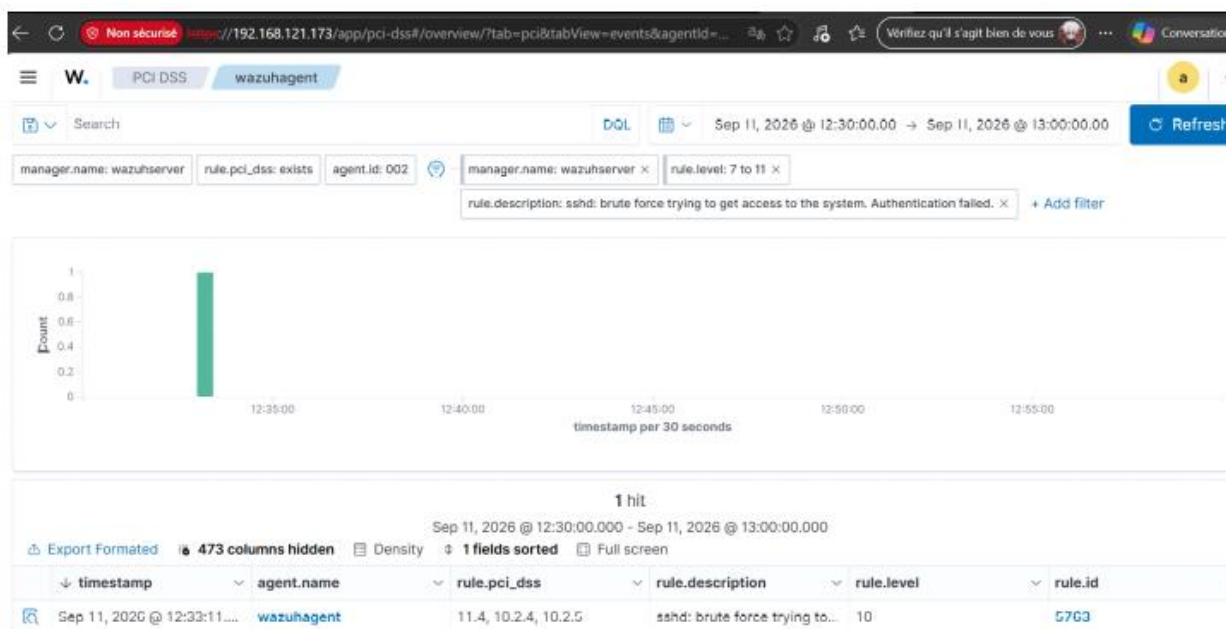
Capture 6 — Lancement de l'attaque brute force SSH (Hydra)

```
root@kali:~# hydra -l tester -P /usr/share/wordlists/rockyou.txt ssh://192.168.121.175 -t 4
Hydra v9.3 (c) 2022 by van Hauser/TMC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-11 12:17:28
[WARNING] Restorefile (you have 18 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 24346299 login tries (1:1/p:14346299), ~2106108 tries per task
[DATA] attacking ssh://192.168.121.175:22/
[STATUS] 36.00 tries/min, 36 tries in 00:01h, 14346361 to do in 6291:34h, 4 active
[STATUS] 26.00 tries/min, 84 tries in 00:03h, 14346315 to do in 8536:17h, 4 active
```

Depuis la machine Red Team, l'outil Hydra est utilisé pour lancer une attaque par force brute sur le service SSH de la VM cible (192.168.121.175), en s'appuyant sur la wordlist rockyou.txt et 4 tâches en parallèle. Le terminal affiche la progression de l'attaque (nombre de tentatives par minute, tentatives restantes, temps estimé).

Capture 7 — Détection de l'attaque brute force par Wazuh



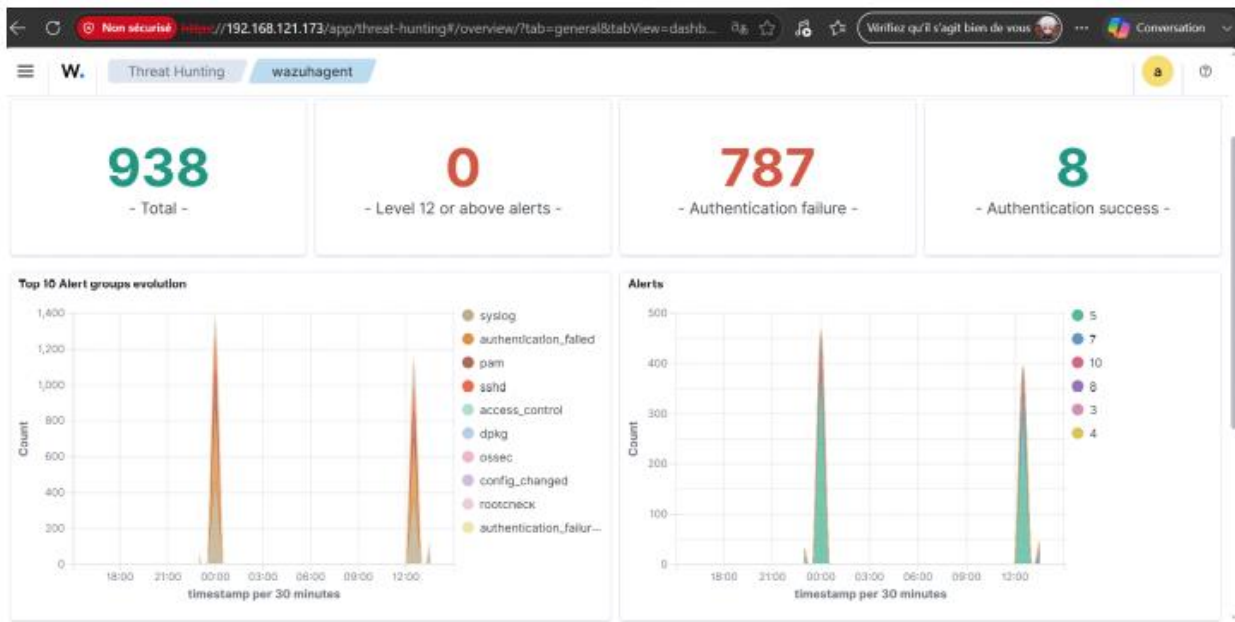
Côté dashboard Wazuh (vue PCI DSS), une alerte de niveau 10 est détectée : règle 5763 « sshd: brute force trying to get access to the system. Authentication failed. ». Cette alerte confirme que Wazuh identifie correctement le comportement de force brute sur le service SSH pendant que l'attaque est en cours.

Capture 8 — Volume d'alertes générées pendant l'attaque

W. PCI DSS wazuagent 74 hits Sep 11, 2026 @ 12:30:00.000 - Sep 11, 2026 @ 13:00:14.697 Export Formatted 473 columns hidden Density 1 fields sorted Full screen						
timestamp	agent.name	rule.pci_dss	rule.description	rule.level	rule.id	
Sep 11, 2026 @ 12:33:12...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	
Sep 11, 2026 @ 12:33:12...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	
Sep 11, 2026 @ 12:33:12...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	
Sep 11, 2026 @ 12:33:12...	wazuagent	10.2.4, 10.2.5	Multiple authentication fail...	10	40111	
Sep 11, 2026 @ 12:33:12...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	
Sep 11, 2026 @ 12:33:12...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	
Sep 11, 2026 @ 12:33:12...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	
Sep 11, 2026 @ 12:33:12...	wazuagent	10.2.4, 10.2.5, 11.4	PAM: Multiple failed logins...	10	5551	
Sep 11, 2026 @ 12:33:11...	wazuagent	10.2.4, 10.2.5	Multiple authentication fail...	10	40111	
Sep 11, 2026 @ 12:33:11...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	
Sep 11, 2026 @ 12:33:11...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	
Sep 11, 2026 @ 12:33:11...	wazuagent	10.2.4, 10.2.5	syslog: User missed the p...	10	2502	

Le détail des alertes sur la fenêtre d'attaque montre 74 événements en quelques secondes, avec plusieurs règles différentes déclenchées : tentatives de connexion échouées (règle 2502 « User missed the password »), échecs d'authentification multiples (règle 40111) et échecs PAM répétés (règle 5551). Ce volume illustre l'intensité caractéristique d'une attaque par force brute automatisée.

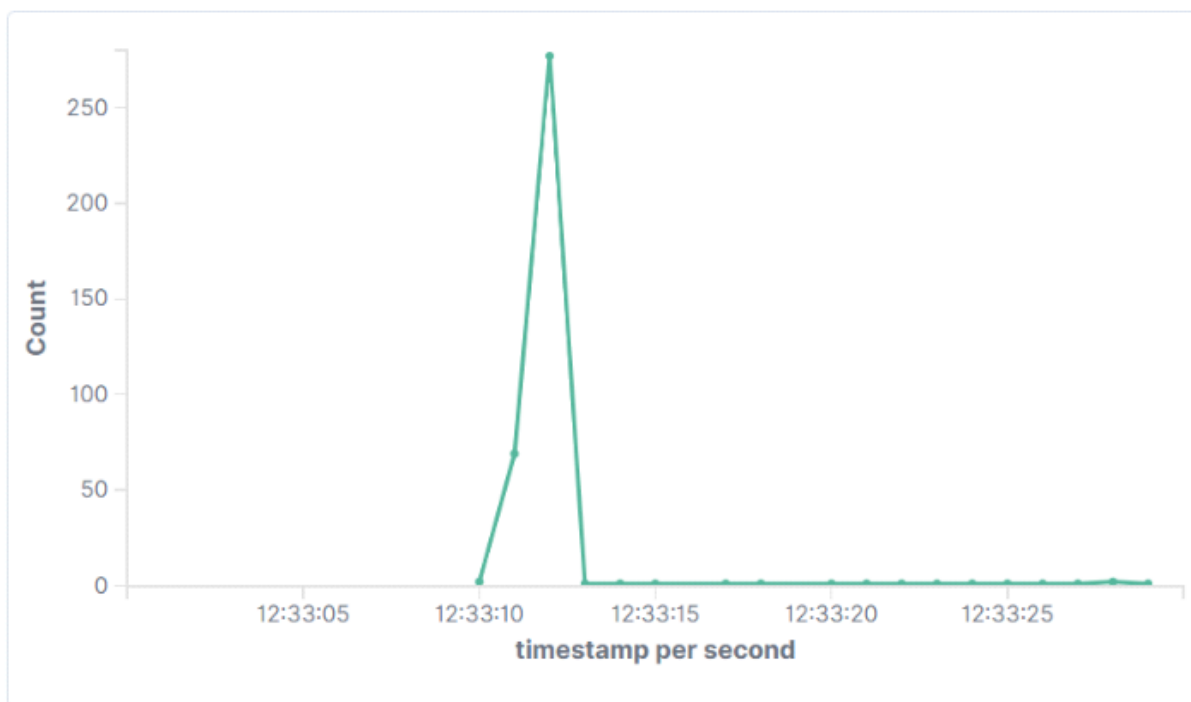
Capture 9 — Synthèse Threat Hunting de l'agent



Le tableau de bord « Threat Hunting » résume l'activité totale de l'agent sur la période observée : 938 alertes, dont 787 liées à des échecs d'authentification contre seulement 8 authentifications réussies. Ce déséquilibre net entre échecs et succès est un indicateur caractéristique d'une tentative de brute force en cours.

Capture 10 — Pic d'événements et temps de détection

Events count evolution



Le graphique « Events count evolution » met en évidence un pic soudain atteignant près de 280 événements par seconde à 12:33:10, correspondant précisément au lancement de l'attaque Hydra, avant un retour rapide à un niveau d'activité normal. Ce type de visualisation est directement exploitable pour mesurer le temps de détection de l'attaque par Wazuh.

Scénario 2 — Exploitation d'une vulnérabilité web (DVWA)

Objectif : exploiter des vulnérabilités applicatives classiques (injection SQL, XSS réfléchi) sur l'application volontairement vulnérable DVWA, et vérifier leur remontée dans Wazuh.

Capture 11 — Démarrage du conteneur DVWA

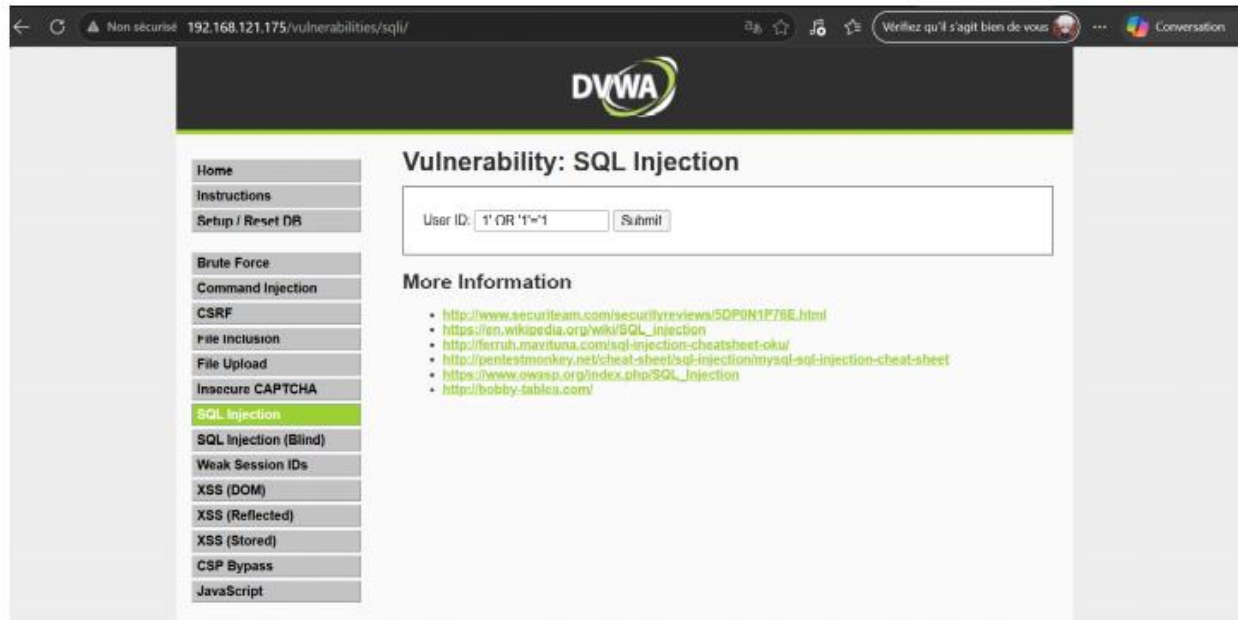
```
root@wazuhagent:~# docker run --rm -it -p 80:80 vulnerables/web-dvwa
Unable to find image 'vulnerables/web-dvwa:latest' locally
docker: Error response from daemon: pull access denied for vulnerables/web-dvwa, repository does not exist or may require 'docker login'

Run 'docker run --help' for more information
root@wazuhagent:~# docker run --rm -it -p 80:80 vulnerables/web-dvwa
Unable to find image 'vulnerables/web-dvwa:latest' locally
latest: Pulling from vulnerables/web-dvwa
b3d4433242d: Pull complete
3e17c6eae66c: Pull complete
ac37d6f16db1: Pull complete
8b95d18be401: Pull complete
e9968e5981d2: Pull complete
2cd72d8a8257: Pull complete
ecff5f35147f: Pull complete
e98cfff43466: Pull complete
Digest: sha256:doc203f611646c86937bf04db0079adcf295f426da68a92b40c5b181f337d3a7
Status: Downloaded newer image for vulnerables/web-dvwa:latest
[+] Starting mysql...
[ok] Starting MariaDB database server: mysqld.
[+] Starting apache
[....] Starting Apache httpd web server: apache2AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 172.17.0.2. Set the 'ServerName' directive globally to suppress this message
[ok]
ss) /var/log/apache2/access.log <==

ss) /var/log/apache2/error.log <==
[Fri Sep 11 14:18:37.179791 2026] [mpm_prefork:notice] [pid 312] AH00163: Apache/2.4.25 (Debian) configured -- resuming normal operations
[Fri Sep 11 14:18:37.179886 2026] [core:notice] [pid 312] AH00094: Command line: '/usr/sbin/apache2'
```

Sur la VM cible, le conteneur Docker DVWA (image vulnerables/web-dvwa) est lancé. Le journal affiche le démarrage des services internes du conteneur : la base de données MariaDB puis le serveur web Apache, prêts à recevoir les requêtes d'attaque applicative (SQLi, XSS).

Capture 12 — Test d'injection SQL sur DVWA



Sur la page « SQL Injection » de DVWA, une première charge utile classique (1' OR '1'='1) est saisie dans le champ User ID, dans le but de contourner la logique de filtrage attendue de la requête SQL sous-jacente.

Capture 13 — Résultat de l'injection SQL



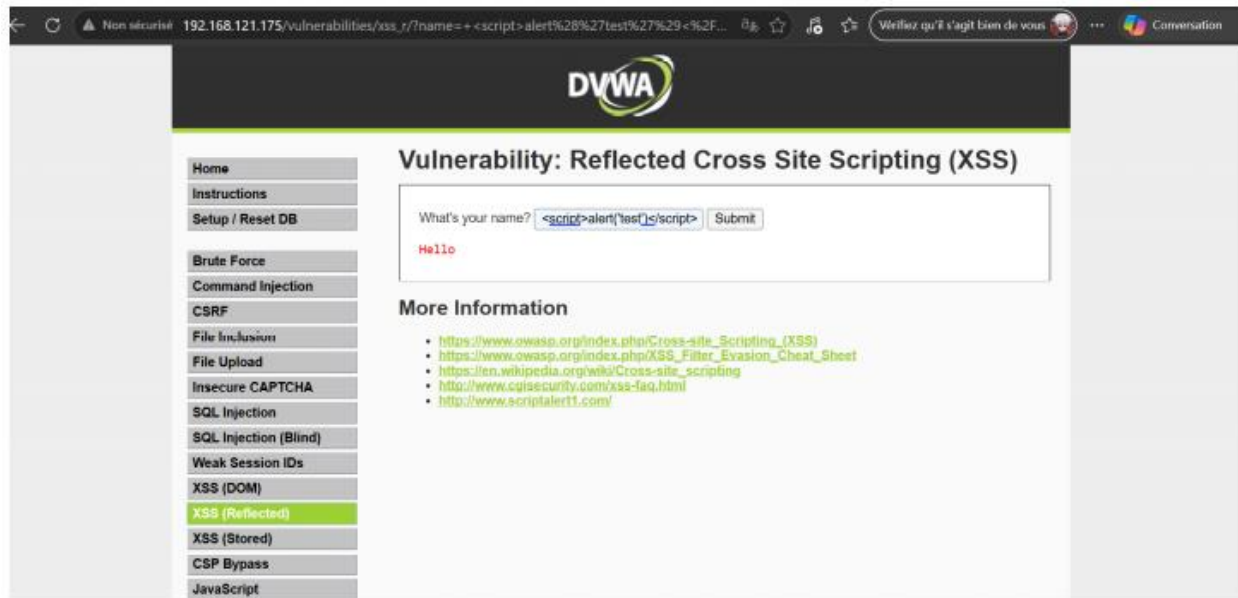
La requête modifiée retourne l'ensemble des utilisateurs enregistrés dans la base de données (admin, Gordon, Hack, Pablo, Bob) au lieu d'un seul enregistrement attendu, ce qui confirme que l'injection SQL a été exécutée avec succès et que l'application est vulnérable.

Capture 14 — Traces de l'attaque dans le journal Apache

```
192.168.121.1 - - [11/Sep/2026:20:11:09 +0000] "GET /vulnerabilities/xss_r/ HTTP/1.1" 200 1753 "http://192.168.121.175/vulnerabilities/xqli/?id=+1%27+OR+%271%27%3D%271&Submit=Submit" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/152.0.0.0 Safari/537.36 Edg/152.0.0.0"
192.168.121.1 - - [11/Sep/2026:20:11:15 +0000] "GET /vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%27test%27%29%3C%2Fscript%3E HTTP/1.1" 200 1777 "http://192.168.121.175/vulnerabilities/xss_r/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/152.0.0.0 Safari/537.36 Edg/152.0.0.0"
```

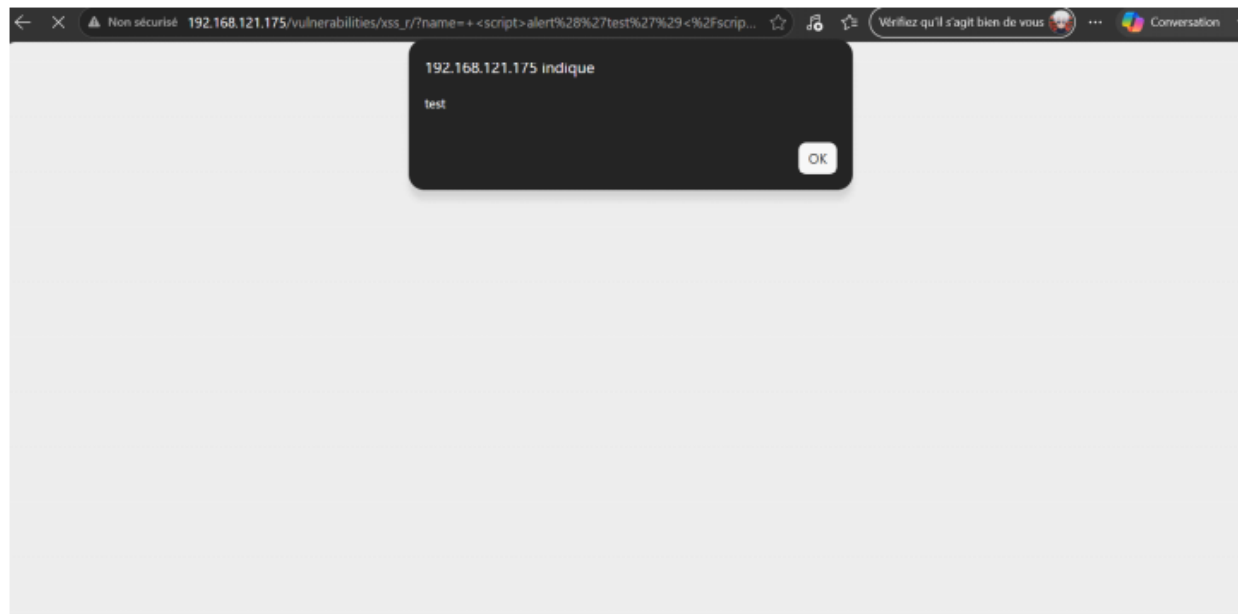
Extrait du fichier access.log du conteneur DVWA montrant les requêtes HTTP correspondant aux tentatives d'injection SQL et de XSS réfléchi, avec les caractères spéciaux (guillemets, chevrons) encodés au format URL (%27, %3Cscript%3E), tel qu'ils transitent réellement sur le réseau.

Capture 15 — Test de XSS réfléchi sur DVWA



Sur la page « XSS (Reflected) » de DVWA, le code `<script>alert('test')</script>` est saisi dans le champ « What's your name? ». La page affiche « Hello » sans neutraliser le contenu injecté, signe que l'entrée utilisateur n'est pas correctement filtrée avant d'être renvoyée dans la réponse HTML.

Capture 16 — Exécution confirmée du script injecté



Une fenêtre pop-up JavaScript affichant « test » apparaît dans le navigateur, preuve irréfutable que le script injecté a bien été exécuté par le navigateur de la victime : la vulnérabilité XSS réfléchi est donc pleinement exploitable.

Capture 17 — Variantes d'attaques supplémentaires

```

192.168.121.1 - - [11/Sep/2026:20:21:01 +0000] "GET /vulnerabilities/sqli/?id=1%27+UNION+SELECT+user%2C+password+FROM+us
ers--&Submit=Submit HTTP/1.1" 200 506 "http://192.168.121.175/vulnerabilities/sqli/?id=http%3A%2F%2F192.168.121.175%2Fvu
lnerabilities%2Fsqli%2F%3Fid%3D1%27+OR+%271%27%3D%271%26Submit%3DSubmit&Submit=Submit" "Mozilla/5.0 (Windows NT 10.0; Wi
n64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/152.0.0.0 Safari/537.36 Edg/152.0.0.0"
192.168.121.1 - - [11/Sep/2026:20:21:44 +0000] "GET /vulnerabilities/sqli/?id=admin%27--&Submit=Submit HTTP/1.1" 200 17
72 "http://192.168.121.175/vulnerabilities/sqli/?id=http%3A%2F%2F192.168.121.175%2Fvulnerabilities%2Fsqli%2F%3Fid%3D1%27
+OR+%271%27%3D%271%26Submit%3DSubmit&Submit=Submit" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
, like Gecko) Chrome/152.0.0.0 Safari/537.36 Edg/152.0.0.0"
192.168.121.1 - - [11/Sep/2026:20:22:07 +0000] "-" 408 0 "-" "-"
192.168.121.1 - - [11/Sep/2026:20:22:29 +0000] "GET /vulnerabilities/xss_r/ HTTP/1.1" 200 1753 "http://192.168.121.175/v
ulnerabilities/sqli/?id=admin%27--&Submit=Submit" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/152.0.0.0 Safari/537.36 Edg/152.0.0.0"
192.168.121.1 - - [11/Sep/2026:20:22:35 +0000] "GET /vulnerabilities/xss_r/?name=%3Cimg+src%3Dx+onerror%3Dalert%28%27XSS
%27%29%3E HTTP/1.1" 200 1780 "http://192.168.121.175/vulnerabilities/xss_r/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/152.0.0.0 Safari/537.36 Edg/152.0.0.0"
192.168.121.1 - - [11/Sep/2026:20:22:35 +0000] "GET /vulnerabilities/xss_r/x HTTP/1.1" 404 518 "http://192.168.121.175/v
ulnerabilities/xss_r/?name=%3Cimg+src%3Dx+onerror%3Dalert%28%27XSS%27%29%3E" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/152.0.0.0 Safari/537.36 Edg/152.0.0.0"
192.168.121.1 - - [11/Sep/2026:20:23:27 +0000] "-" 408 0 "-" "-"

```

Le journal Apache capture d'autres tentatives : une injection SQL par UNION SELECT visant à extraire les identifiants et mots de passe de la table users, une tentative de contournement d'authentification (admin'--), ainsi qu'une variante de XSS utilisant la balise pour contourner un éventuel filtrage limité aux balises <script>.

Capture 18 — Alerte JSON brute pour la variante XSS

```

1.175"}, "manager": {"name": "wazuhserver"}, "id": "1789158155.618419", "full_log": "192.168.121.1 - - [11/Sep/2026:20:22:35 +0000] \
\"GET /vulnerabilities/xss_r/x HTTP/1.1\" 404 518 \"http://192.168.121.175/vulnerabilities/xss_r/?name=%3Cimg+src%3Dx+onerror%3D
alert%28%27XSS%27%29%3E\\\" \\\"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/152.0.0.0 S
afari/537.36 Edg/152.0.0.0\\\"\", \"decoder\": {\"name\": \"web-accesslog\"}, \"data\": {\"protocol\": \"GET\", \"srcip\": \"192.168.121.1\", \"id\": \"404\", \"u
rl\": \"/vulnerabilities/xss_r/x/\", \"location\": \"/home/aby/dvwa-logs/access.log\"}

```

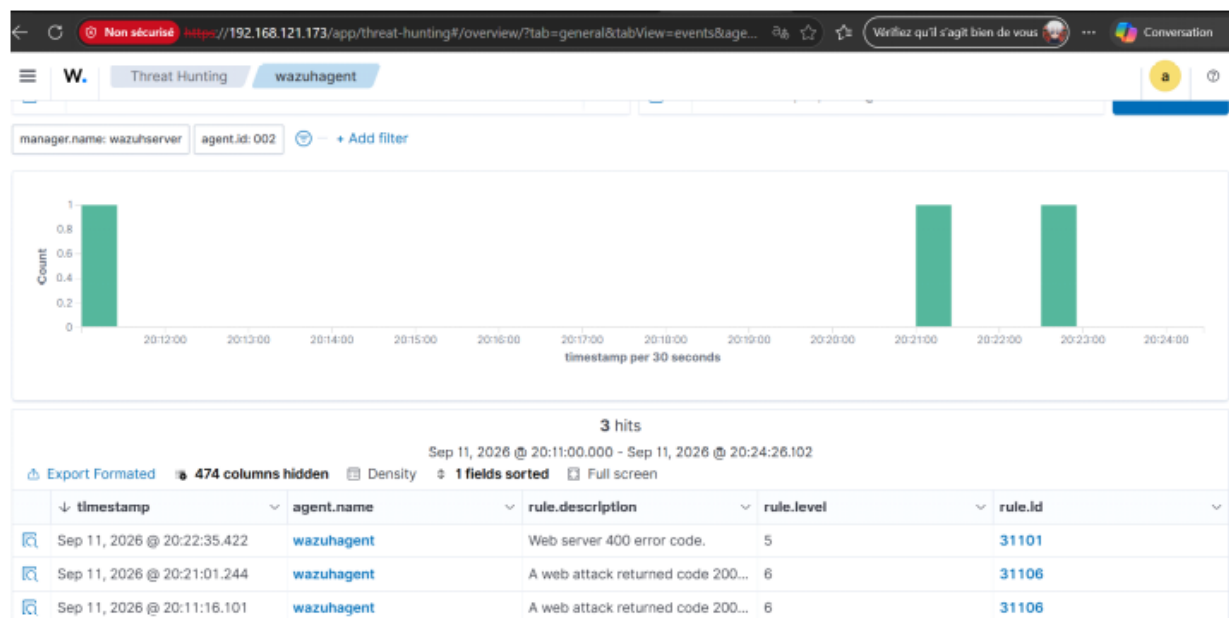
Extrait brut (format JSON) d'une alerte générée pour la tentative XSS basée sur la balise , avec un code retour HTTP 404. Le décodeur « web-accesslog » de Wazuh a correctement identifié la méthode HTTP, l'adresse IP source et l'URL complète de la requête suspecte.

Capture 19 — Alerte isolée pour la première injection XSS



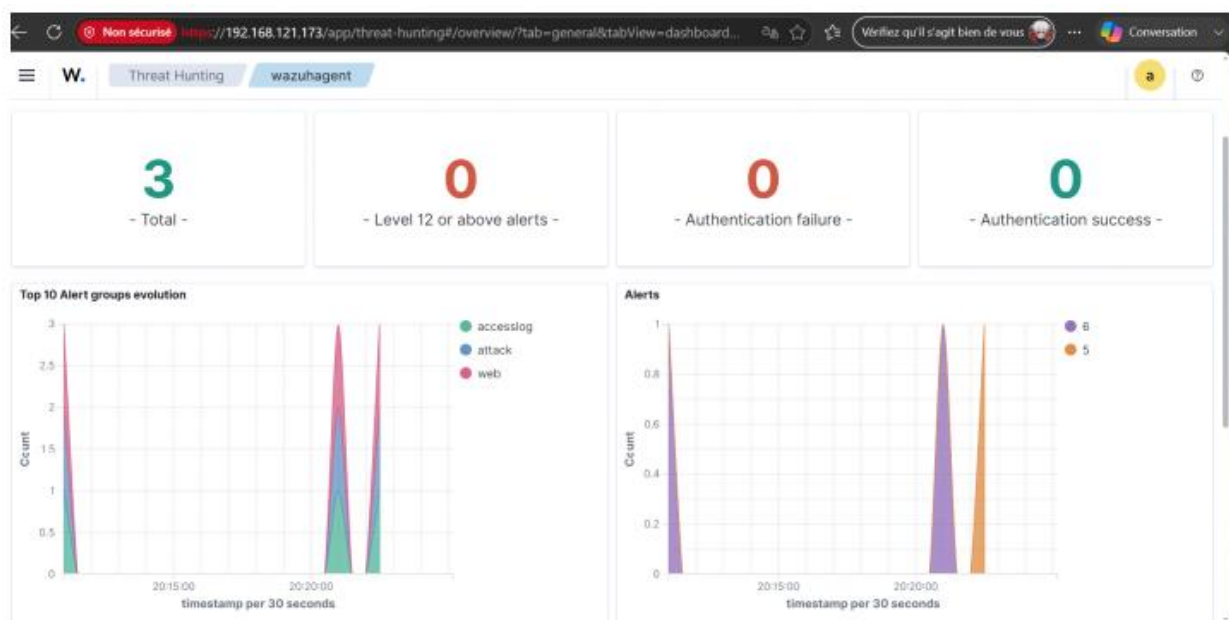
Dans la vue « Threat Hunting > Events », l'alerte associée à la première injection XSS réfléchie est isolée : règle 31106 (« A web attack returned code 200 »), de niveau 6, déclenchée quelques secondes seulement après l'envoi de la requête depuis le navigateur.

Capture 20 — Ensemble des alertes web sur la session de test

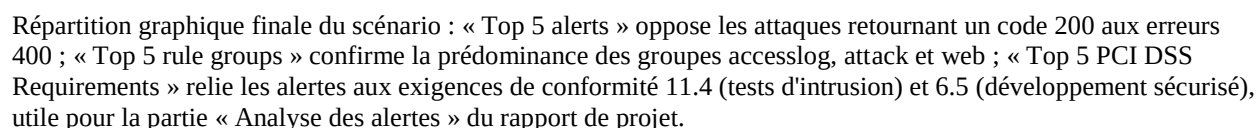


Vue consolidée des alertes web générées pendant la session de test : deux attaques détectées avec un code de retour 200 (règle 31106) et une erreur 400 (règle 31101), réparties dans le temps selon les différentes tentatives d'injection SQL et XSS effectuées manuellement.

Capture 21 — Tableau de bord récapitulatif du scénario DVWA



Capture 22 — Répartition des alertes et conformité PCI DSS



Objectif : simuler le dépôt d'un fichier malveillant sur la machine cible, sans manipuler de malware réel, et vérifier la détection via l'intégration VirusTotal de Wazuh couplée au module FIM (File Integrity Monitoring).

Depuis la machine Red Team (Kali), le fichier de test standard EICAR est téléchargé via wget depuis secure.eicar.org. Ce fichier est totalement inoffensif, mais reconnu par tous les moteurs antivirus du monde comme un « virus de test » — il permet de simuler un dépôt de malware sans manipuler de code malveillant réel.

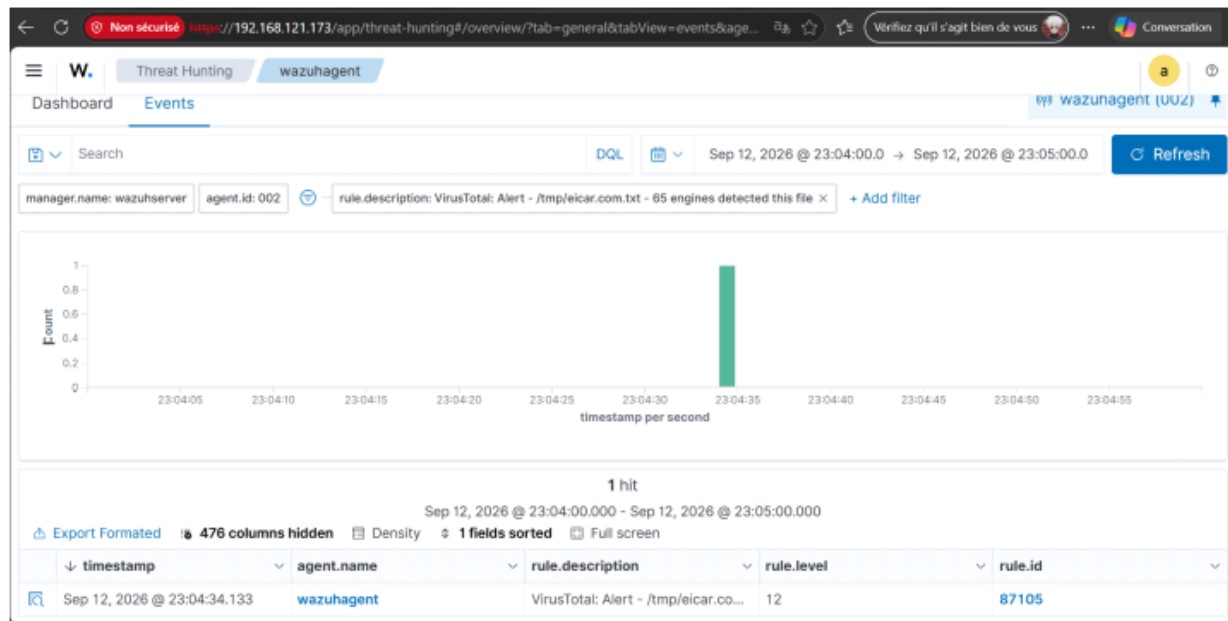
```
root@kali:~# cat /dev/urandom | tr -dc 'a-z0-9' | fold -n 32 | xargs printf '%32s\n' | shuf -v | tee testuser2102.121.175.txt
Sat Sep 12 23:04:19 GMT 2020

root@kali:~# cat /dev/urandom | tr -dc 'a-z0-9' | fold -n 32 | xargs printf '%32s\n' | shuf -v | tee testuser2102.121.175.txt
testuser2102.121.175's password:
#icar-com.txt
100% 68 32.4KB/s 00:00

root@kali:~#
```

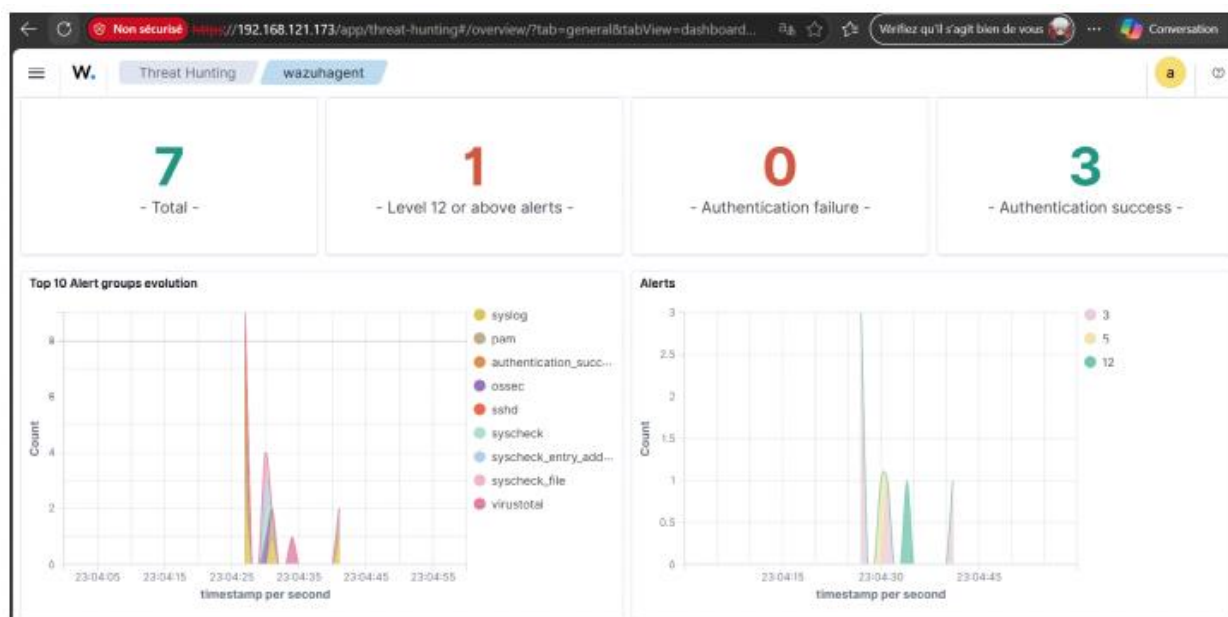
Le fichier eicar.com.txt est transféré via scp vers la VM cible (192.168.121.175), dans le répertoire /tmp/ — simulant le dépôt d'un fichier malveillant sur un poste compromis, par exemple à la suite d'un téléchargement piégé ou d'une clé USB infectée.

Capture 25 — Détection par l'intégration VirusTotal de Wazuh



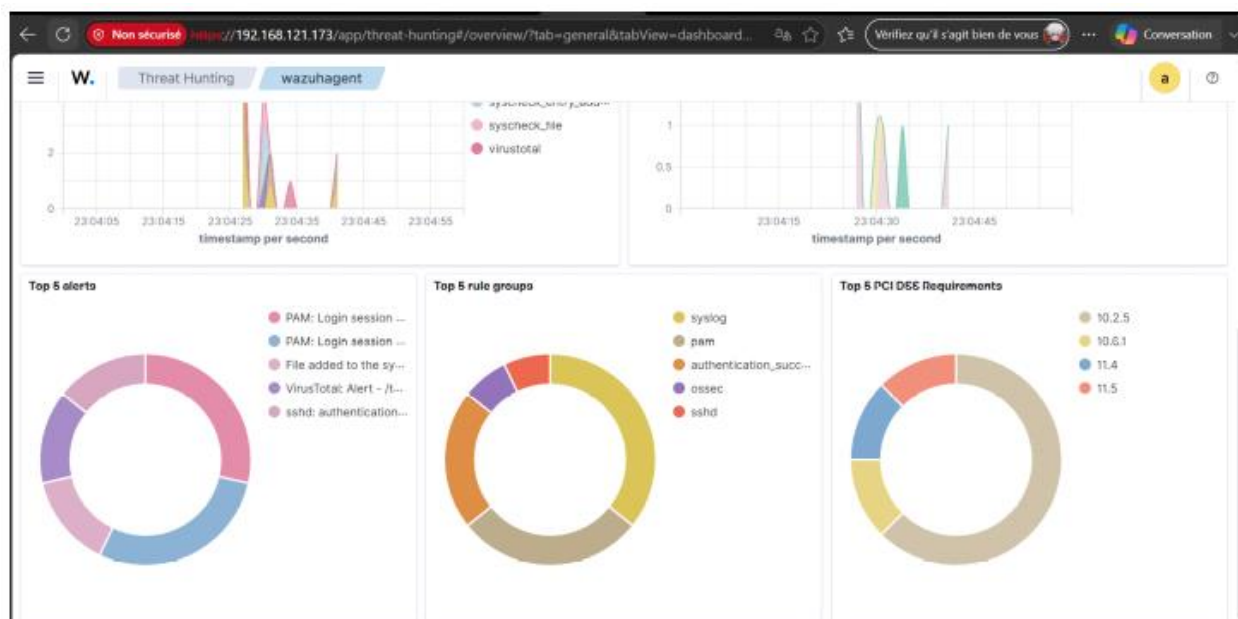
Grâce au module FIM (File Integrity Monitoring) surveillant le répertoire /tmp, Wazuh détecte la création du nouveau fichier et interroge automatiquement l'API VirusTotal avec son empreinte (hash). La réponse confirme que 65 moteurs antivirus sur VirusTotal reconnaissent le fichier comme malveillant. Une alerte de niveau 12 (règle 87105 « VirusTotal: Alert - /tmp/eicar.com.txt - 65 engines detected this file ») est générée, sans qu'aucune règle personnalisée n'ait été nécessaire.

Capture 26 — Synthèse Threat Hunting du scénario malware



Le tableau de bord de l'agent affiche 7 alertes au total pour ce scénario, dont 1 de niveau 12 ou supérieur (le verdict VirusTotal) — le reste correspondant aux événements FIM classiques (ajout de fichier, sessions PAM autour de la manipulation). La chronologie des événements montre une activité concentrée sur quelques secondes autour du dépôt du fichier.

Capture 27 — Répartition des alertes et conformité pour le scénario malware



Les graphiques « Top 5 alerts », « Top 5 rule groups » et « Top 5 PCI DSS Requirements » confirment la prédominance des groupes syscheck (surveillance de fichiers) et virustotal, ainsi que le rattachement de l'alerte aux exigences PCI DSS 10.2.5, 10.6.1, 11.4 et 11.5, liées à la détection de logiciels malveillants et à la surveillance de l'intégrité des systèmes.

Scénario 4 — Mouvement latéral

Objectif : à partir de la machine déjà compromise lors des scénarios précédents, pivoter vers une autre machine du réseau interne (le serveur Wazuh) pour simuler la propagation d'un attaquant au sein du système d'information, et vérifier que Wazuh qualifie correctement ce comportement selon le framework MITRE ATT&CK.

Capture 28 — Préparation d'un compte cible sur le serveur Wazuh

```
root@wazuhserver:~# sudo adduser adminweb
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for adminweb
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n] Y
root@wazuhserver:~#
```

No VM guests are running outdated hypervisor (qemu) binaries on this host.

Capture 29 — Installation de l'outil d'attaque sur la machine compromise

Depuis la VM cible (wazuhagent, déjà compromise lors des scénarios précédents de brute force et d'injection web), l'outil hydra est installé via apt. C'est une étape clé du mouvement latéral : l'attaquant ne revient pas sur sa machine Kali, mais utilise directement la machine déjà infiltrée comme point de rebond (pivot) pour attaquer d'autres systèmes du réseau interne.

[illegible]

Capture 31 — Attaque par pivot vers le serveur Wazuh

```

root@azuhagent:~# sudo mv rockyou.txt /usr/share/wordlists/
root@azuhagent:~# date
Sun 13 sept 2026 13:32:45 UTC
root@azuhagent:~# hydra -l adminweb -P /usr/share/wordlists/rockyou.txt ssh://192.168.121.173 -t 4
hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these
*** ignore laws and ethics anyway).

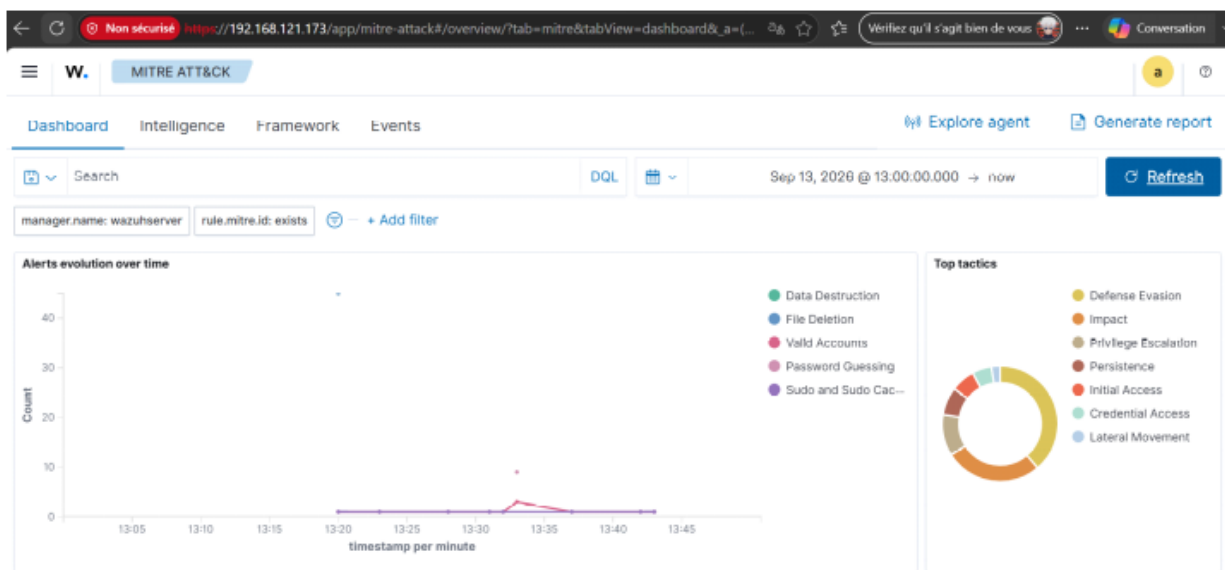
hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-13 13:32:52
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344398 login tries (1:1/p:14344398), ~3586100 tries per task
[DATA] attacking ssh://192.168.121.173:22/
[22][ssh] host: 192.168.121.173 login: adminweb password: 123456
1 of 1 target successfully completed, 1 valid password found
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-13 13:33:01
root@azuhagent:~#

```

Depuis wazuhagent (192.168.121.175), une attaque par force brute SSH est lancée avec Hydra vers le serveur Wazuh (192.168.121.173), en ciblant le compte adminweb créé précédemment. Hydra trouve un mot de passe valide (adminweb:123456) en quelques secondes. Cette étape illustre concrètement le mouvement latéral : la machine

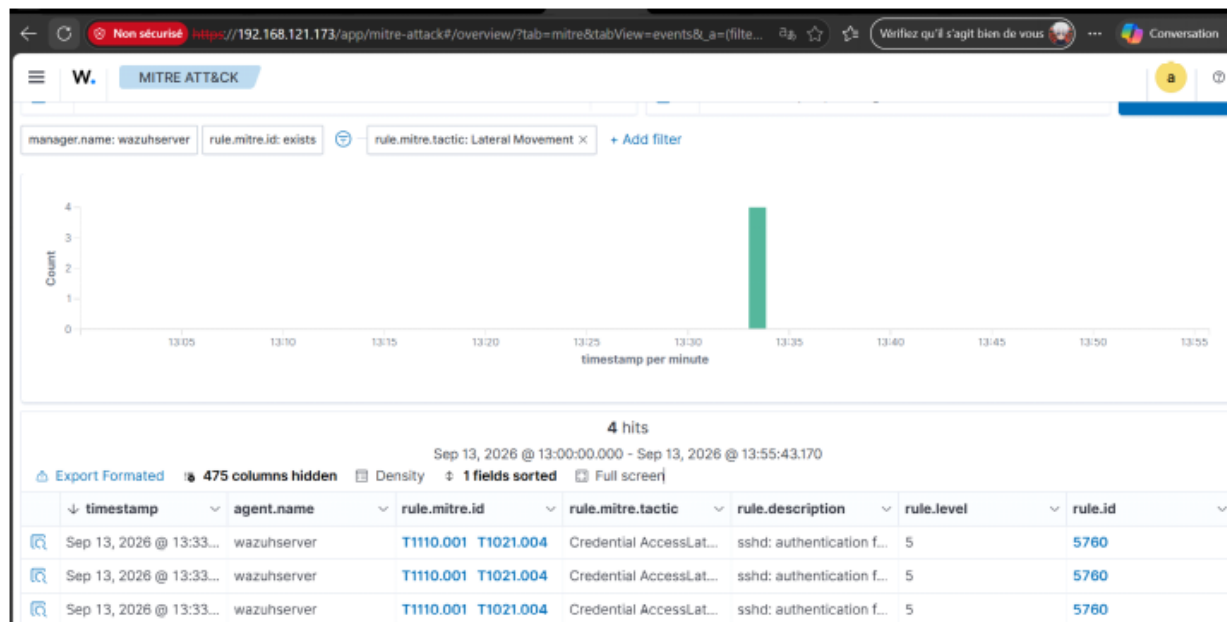
compromise en premier sert de rebond pour atteindre une machine plus sensible du réseau, ici le serveur de supervision lui-même.

Capture 32 — Vue d'ensemble MITRE ATT&CK sur le manager



Le module MITRE ATT&CK du dashboard Wazuh, filtré sur le serveur (wazuhserver), affiche l'évolution des alertes classées par tactique : Defense Evasion, Impact, Valid Accounts, Privilege Escalation, Persistence, Initial Access, Credential Access, Password Guessing et Lateral Movement. Cette cartographie automatique permet de relier chaque alerte technique à une phase reconnue d'une cyberattaque réelle.

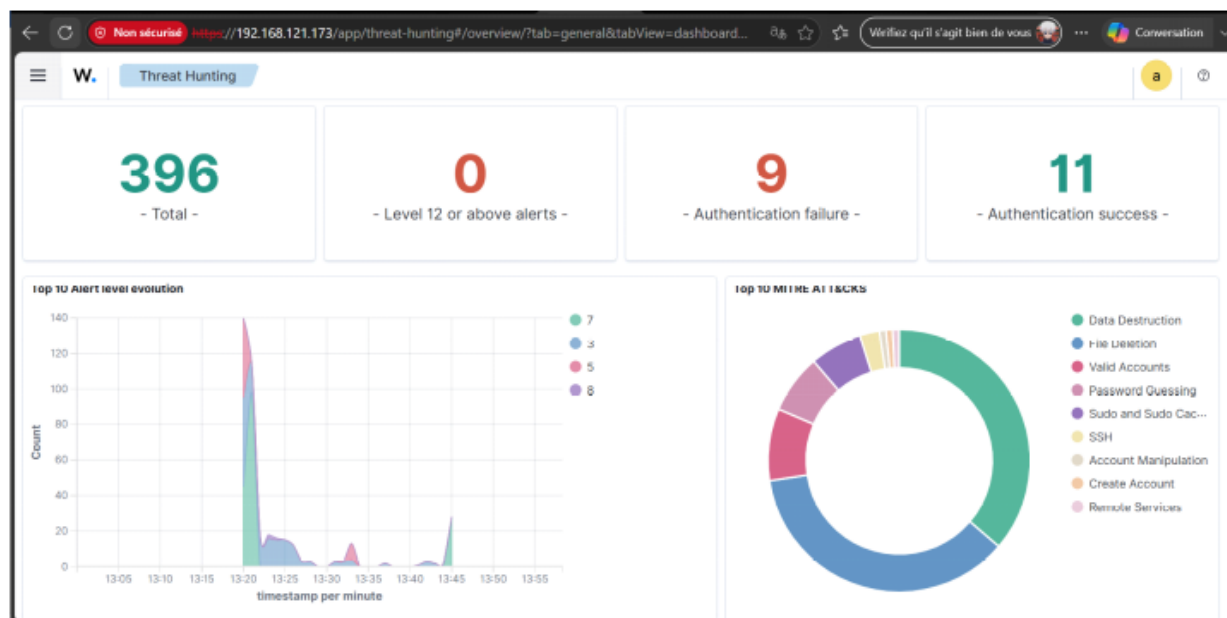
Capture 33 — Alertes classées « Lateral Movement »



En filtrant spécifiquement sur la tactique MITRE ATT&CK « Lateral Movement », 4 alertes apparaissent sur le serveur, associées aux techniques T1110.001 (Password Guessing) et T1021.004 (Remote Services : SSH), avec la règle 5760 (« sshd: authentication failed »). Cela démontre que Wazuh ne détecte pas seulement l'échec de

connexion, mais le qualifie explicitement comme relevant d'un mouvement latéral selon le framework MITRE ATT&CK.

Capture 34 — Vue Threat Hunting globale du serveur



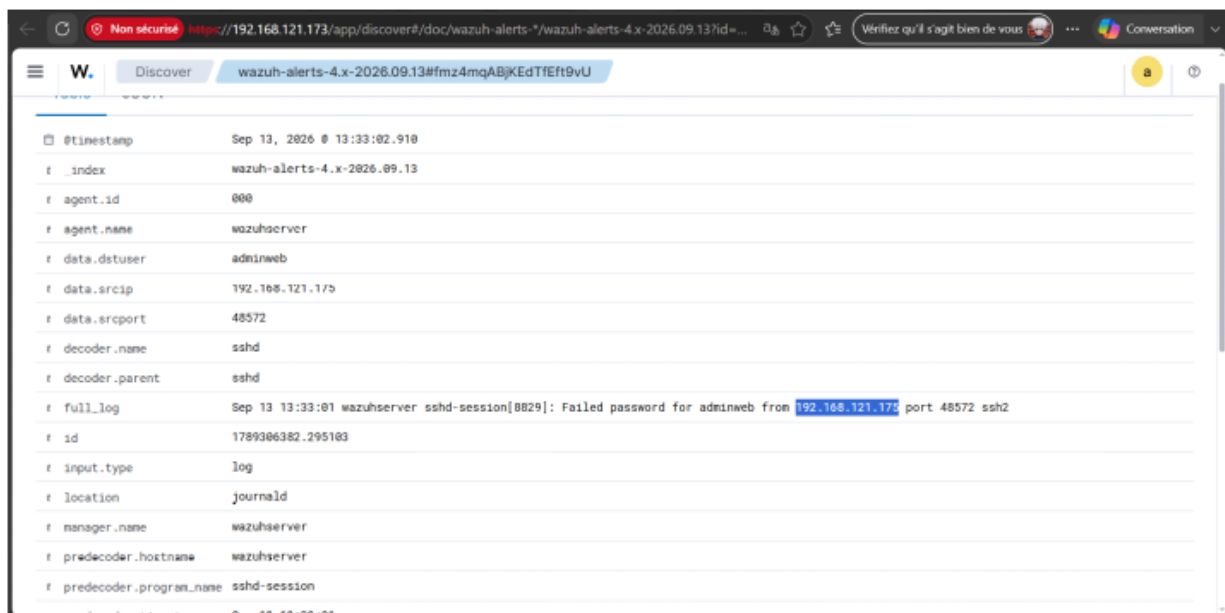
Le tableau de bord Threat Hunting du serveur (agent 000, wazuhserver) affiche 396 alertes au total sur la période, avec 9 échecs d'authentification et 11 authentifications réussies. Le pic de niveau 7 vers 13:20 correspond à l'activité initiale sur la machine cible, avant que l'attaque ne se propage vers le serveur autour de 13:33-13:45.

Capture 35 — Comparaison de l'activité entre les deux agents



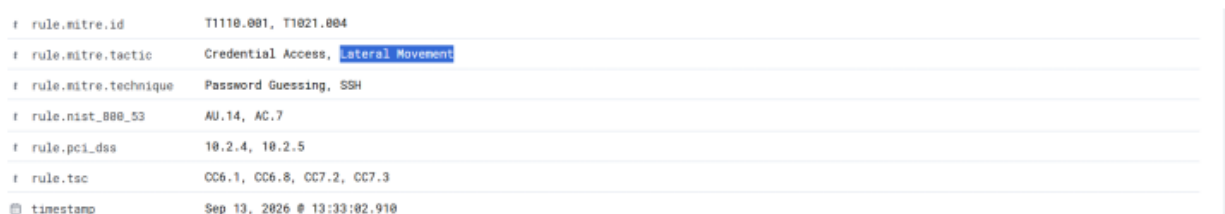
La vue comparative « Top 5 agents » met en parallèle l'activité de wazuhagent (pic important vers 13:20, correspondant aux scénarios précédents) et de wazuhserver (second pic vers 13:45, correspondant à l'attaque par pivot). Cette superposition temporelle est une preuve visuelle forte du mouvement latéral : l'attaque se déplace clairement d'une machine à l'autre dans le temps.

Capture 36 — Preuve de l'origine du pivot dans les journaux



La vue Discover détaille un événement précis : un échec d'authentification pour l'utilisateur adminweb sur wazuhserv, avec pour adresse IP source 192.168.121.175 — c'est-à-dire l'adresse de la VM cible déjà compromise, et non celle de la machine Kali d'origine. C'est la preuve technique directe que l'attaque contre le serveur provient bien de la machine pivot, confirmant le scénario de mouvement latéral.

Capture 37 — Qualification MITRE ATT&CK de l'événement



Le détail de l'alerte confirme son rattachement MITRE ATT&CK : technique T1110.001 / T1021.004, tactiques Credential Access et Lateral Movement, technique déclarée Password Guessing / SSH. Cette double qualification (technique et tactique) permet de documenter précisément la manière dont l'attaquant a exploité un compte faible pour se déplacer latéralement vers une machine plus critique du réseau.

Synthèse — Résultats attendus

Chronologie de l'attaque

Les quatre scénarios ont été exécutés de manière séquentielle : (1) attaque brute force SSH depuis Kali, (2) exploitation de vulnérabilités web sur DVWA hébergée en conteneur Docker, (3) dépôt d'un fichier malveillant simulé (EICAR) sur la machine cible, puis (4) utilisation de cette même machine, déjà compromise, comme point de rebond pour attaquer le serveur Wazuh lui-même. Cette progression reproduit une chaîne d'attaque réaliste, du point d'entrée initial jusqu'à la propagation interne (kill chain).

Analyse des alertes

Chaque scénario a généré des alertes cohérentes avec la nature de l'attaque : règles sshd/PAM pour le brute force, règles web_attacks/accesslog pour les injections DVWA, règle VirusTotal pour le malware simulé, et règles sshd qualifiées par le framework MITRE ATT&CK (tactique « Lateral Movement », techniques T1110.001 et T1021.004) pour le pivot final. L'usage du module MITRE ATT&CK de Wazuh permet de relier chaque alerte technique à une étape reconnue d'une cyberattaque, ce qui renforce la lisibilité de l'analyse pour un public non expert.

Mesure du temps de détection

Le tableau ci-dessous récapitule des estimations de délai entre le lancement de chaque attaque et l'apparition de la première alerte correspondante dans Wazuh, à partir des horodatages visibles dans les captures. Ces valeurs sont indicatives et gagneraient à être recalculées précisément à partir des fichiers alerts.json bruts pour le rapport final.

Scénario	Heure de l'action	Heure de détection	Délai estimé
1. Brute force SSH	~12:27:24 (lancement Hydra)	12:33:11 (règle 5763)	≈ 6mn
2. XSS réfléchi et Injection SQL (DVWA)	20:11:15 (requête envoyée)	20:11:16 (règle 31106)	≈ 1 seconde
3. Malware simulé (EICAR)	23:04:19 (dépôt du fichier)	23:04:34 (règle 87105, VirusTotal)	≈ 15 secondes (latence API VirusTotal)
4. Mouvement latéral	13:32:45 (lancement Hydra depuis le pivot)	13:33:02 (règle 5760, MITRE Lateral Movement)	≈ 17 secondes

On observe que les attaques réseau et applicatives (brute force, XSS) sont détectées quasi instantanément par le moteur de corrélation local de Wazuh, tandis que le scénario malware, qui dépend d'un appel à une API externe (VirusTotal), introduit une latence supplémentaire liée au temps de réponse réseau. Le scénario de mouvement latéral, bien que plus complexe dans sa mise en œuvre, reste détecté en quelques secondes grâce à la surveillance continue des journaux d'authentification sur le serveur cible.